Sandbox 2.1 Lab assignment

10/30/2026

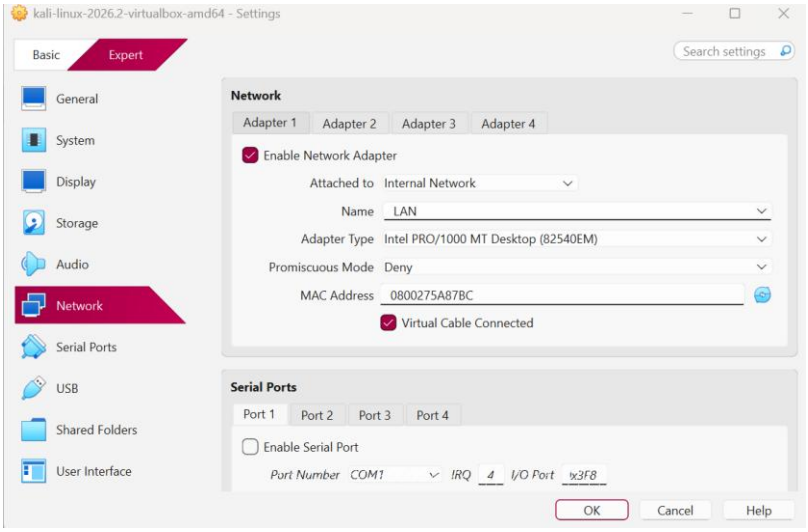
Part 1:

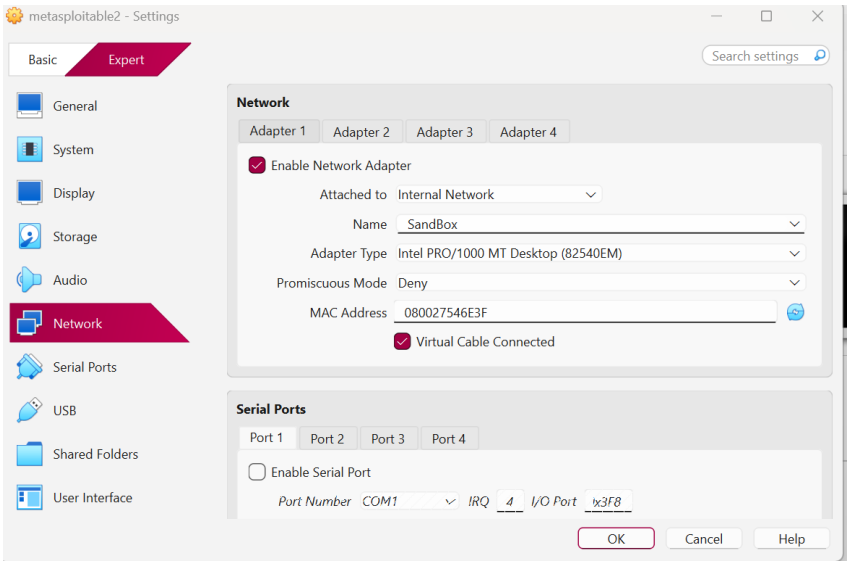
Question:

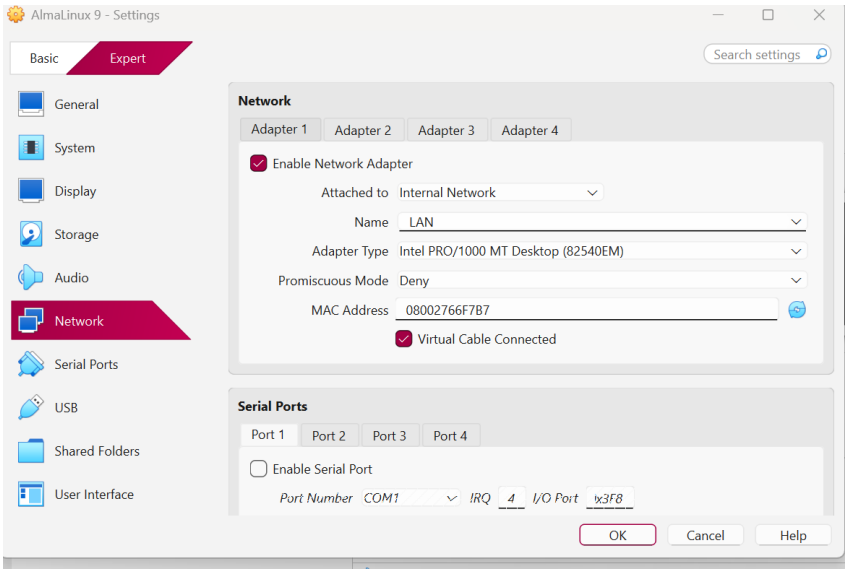
○ What security assumptions are violated when a vulnerable host is connected directly to a NAT network instead of an isolated internal segment behind a firewall? Your response should reference trust boundaries, enforcement visibility, and exposure surface.

- When connected to a NAT rather than being an isolated internal segment. It is not placed within an enforced trust zone. NAT gives it; its own path, so it does not respect those divisions. Visibility is enabled because it allows monitoring so that when traffic passes, there's a checkpoint in place to make sure nothing goes through that is not supposed to be there. By having the network connected to NAT, pfSense can't apply any rules because it bypasses the firewall and can’t be logged. The assumption that “all traffic is observable and governable” is broken. Altogether NAT removes the trust boundaries and can no longer be observed, so any malicious activity can pass through without any log of it.

Screenshots:


kali-linux-2026.2-virtualbox-amd64 - Settings
Basic
Expert
Search settings
General
System
Display
Storage
Audio
Network
Serial Ports
USB
Shared Folders
User Interface
Network
Adapter 1
Adapter 2
Adapter 3
Adapter 4
Enable Network Adapter
Attached to
Internal Network
Name
LAN
Adapter Type
Intel PRO/1000 MT Desktop (82540EM)
Promiscuous Mode
Deny
MAC Address
0800275A87BC
Virtual Cable Connected
Serial Ports
Port 1
Port 2
Port 3
Port 4
Enable Serial Port
Port Number
COM1
IRQ
4
I/O Port
0x3F8
OK
Cancel
Help


metasploitable2 - Settings
Basic
Expert
Search settings
General
System
Display
Storage
Audio
Network
Serial Ports
USB
Shared Folders
User Interface
Network
Adapter 1
Adapter 2
Adapter 3
Adapter 4
Enable Network Adapter
Attached to
Internal Network
Name
SandBox
Adapter Type
Intel PRO/1000 MT Desktop (82540EM)
Promiscuous Mode
Deny
MAC Address
080027546E3F
Virtual Cable Connected
Serial Ports
Port 1
Port 2
Port 3
Port 4
Enable Serial Port
Port Number
COM1
IRQ
4
I/O Port
0x3F8
OK
Cancel
Help



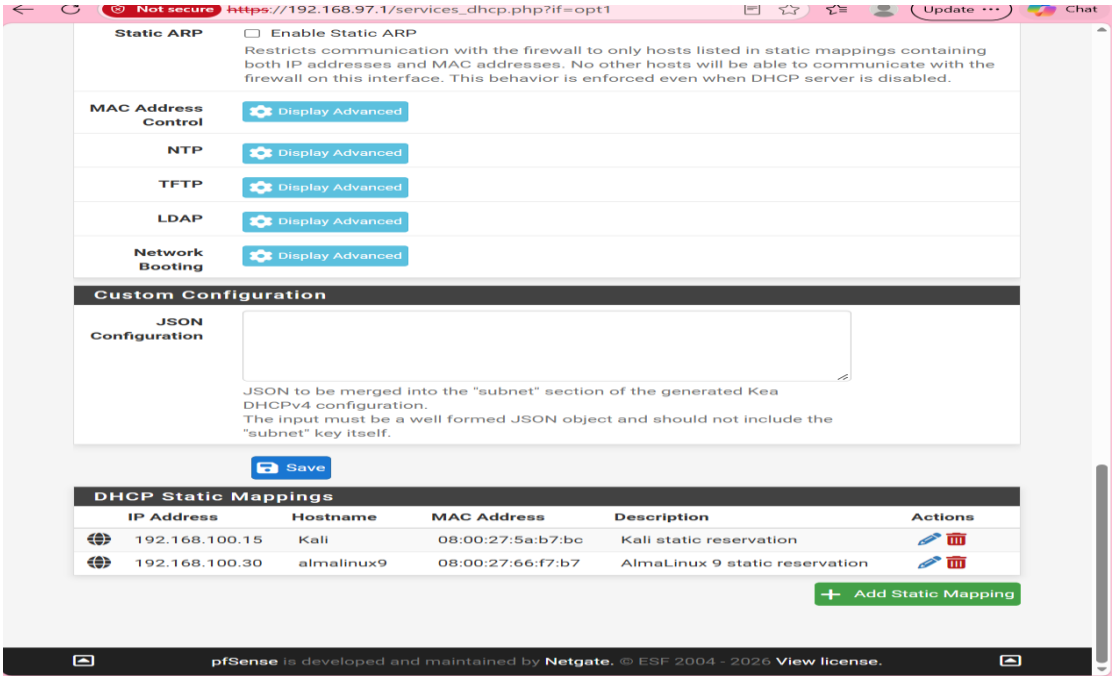
Part 2:

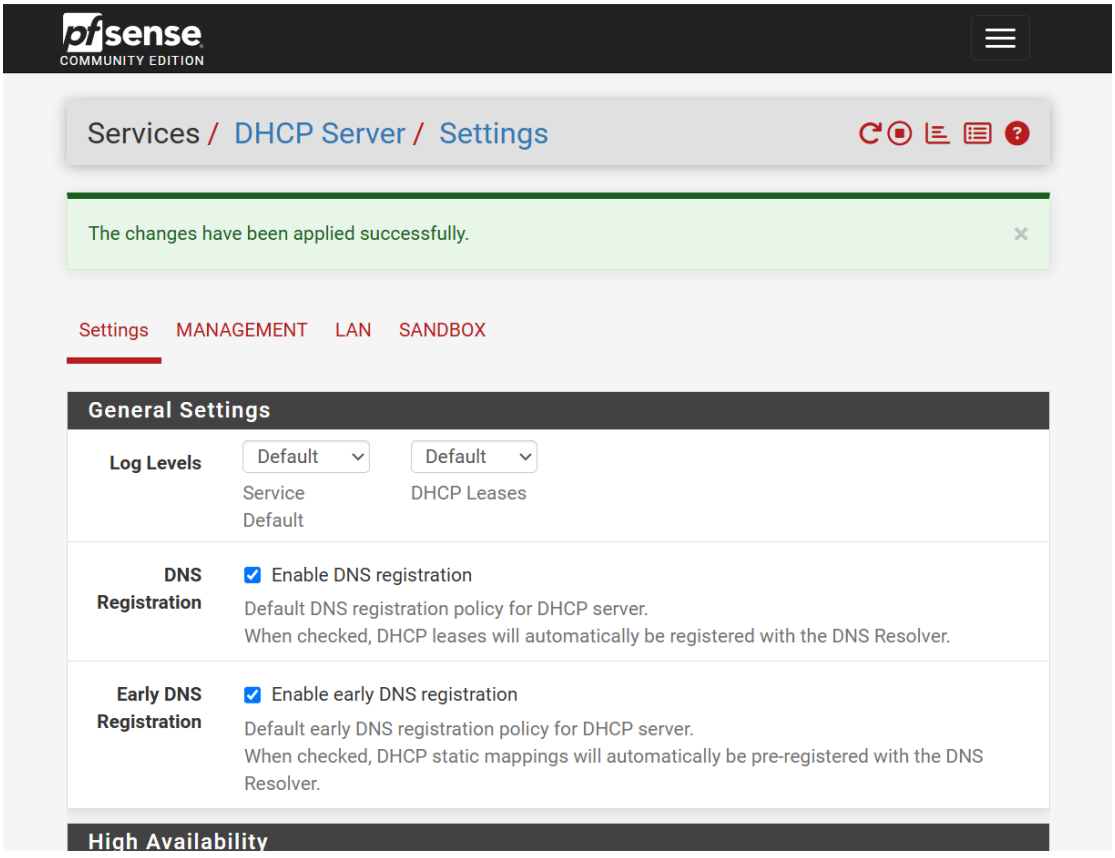
Question:

○ What would be the benefit of setting up the static mapping for a machine

inside of PFSense as opposed to on the machine itself?

- By adding it in the pfsense it centralizes the addressing in one authority location. This will prevent it from switching to different hosts and firewalls.


Not secure https://192.168.97.1/services_dhcp.php?if=opt1
Update
Chat
Static ARP
Enable Static ARP
Restricts communication with the firewall to only hosts listed in static mappings containing both IP addresses and MAC addresses. No other hosts will be able to communicate with the firewall on this interface. This behavior is enforced even when DHCP server is disabled.
MAC Address Control
Display Advanced
NTP
Display Advanced
TFTP
Display Advanced
LDAP
Display Advanced
Network Booting
Display Advanced
Custom Configuration
JSON Configuration
JSON to be merged into the "subnet" section of the generated Kea DHCPv4 configuration.
The input must be a well formed JSON object and should not include the "subnet" key itself.
Save
DHCP Static Mappings
IP Address
Hostname
MAC Address
Description
Actions
192.168.100.15
Kali
08:00:27:5a:b7:bc
Kali static reservation
192.168.100.30
almalinux9
08:00:27:66:f7:b7
AlmaLinux 9 static reservation
Add Static Mapping
pfSense is developed and maintained by Netgate. © ESF 2004 - 2026 View license.

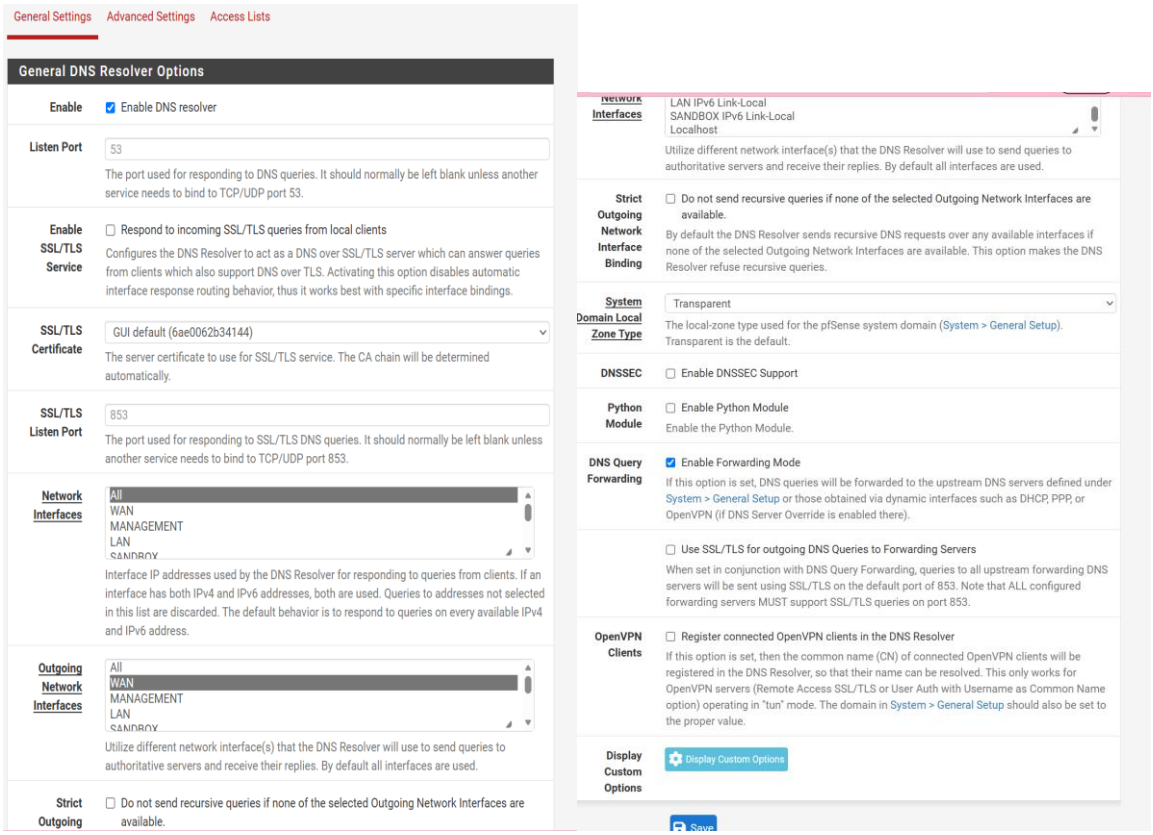

pfsense
COMMUNITY EDITION
Services / DHCP Server / Settings
The changes have been applied successfully.
Settings
MANAGEMENT
LAN
SANDBOX
General Settings
Log Levels
Default
Default
Service
DHCP Leases
Default
DNS Registration
Enable DNS registration
Default DNS registration policy for DHCP server.
When checked, DHCP leases will automatically be registered with the DNS Resolver.
Early DNS Registration
Enable early DNS registration
Default early DNS registration policy for DHCP server.
When checked, DHCP static mappings will automatically be pre-registered with the DNS Resolver.
High Availability

Step 3:

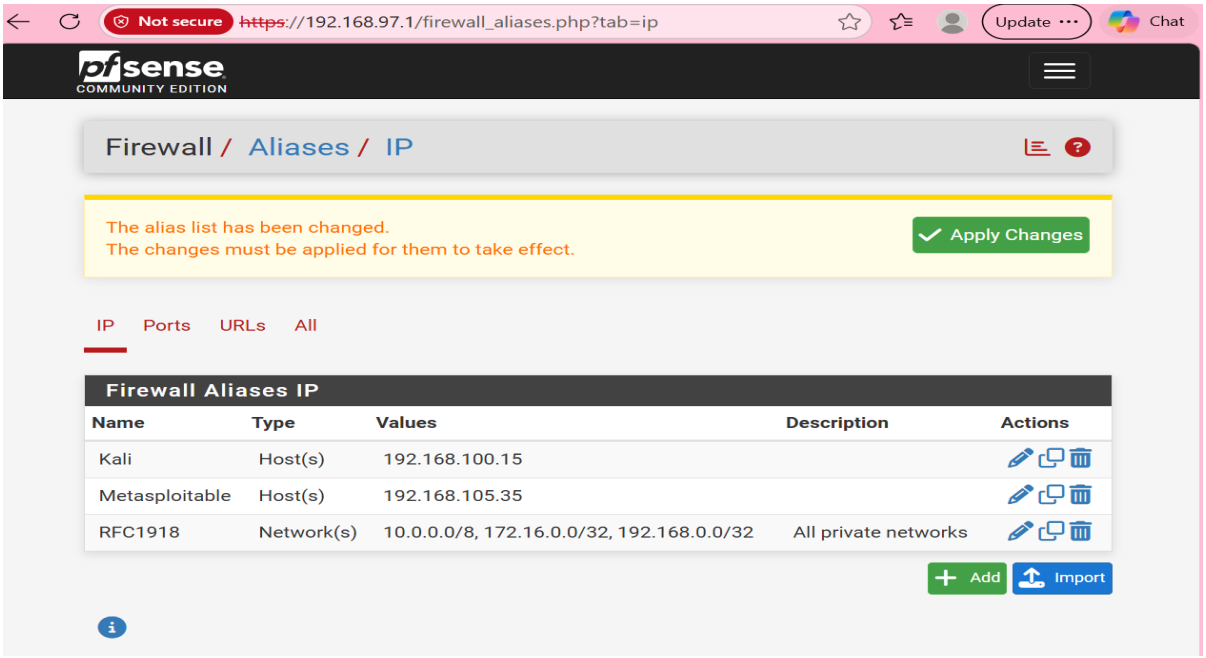
Question:

○ In an enterprise environment DNSSEC improves integrity and trust validation. Why might disabling DNSSEC simplify troubleshooting and Reduce instability in a controlled lab environment?

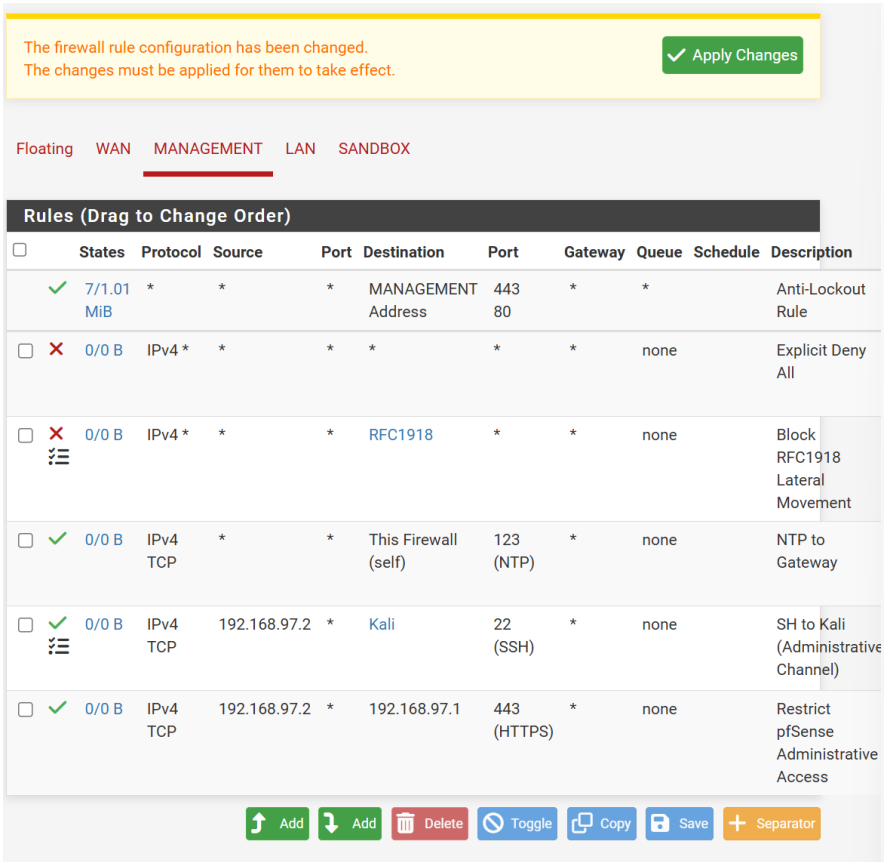
- Disabling this feature will simplify the troubleshooting aspect of this lab. Having this feature adds an extra layer of security that could potentially fail. If it ends failing, it does not just alert a warning; it will simply block the whole resolution. With labs like this; they are controlled so it's not a real-world attack where I am trying to defend real DNS, so the extra layer is not needed.

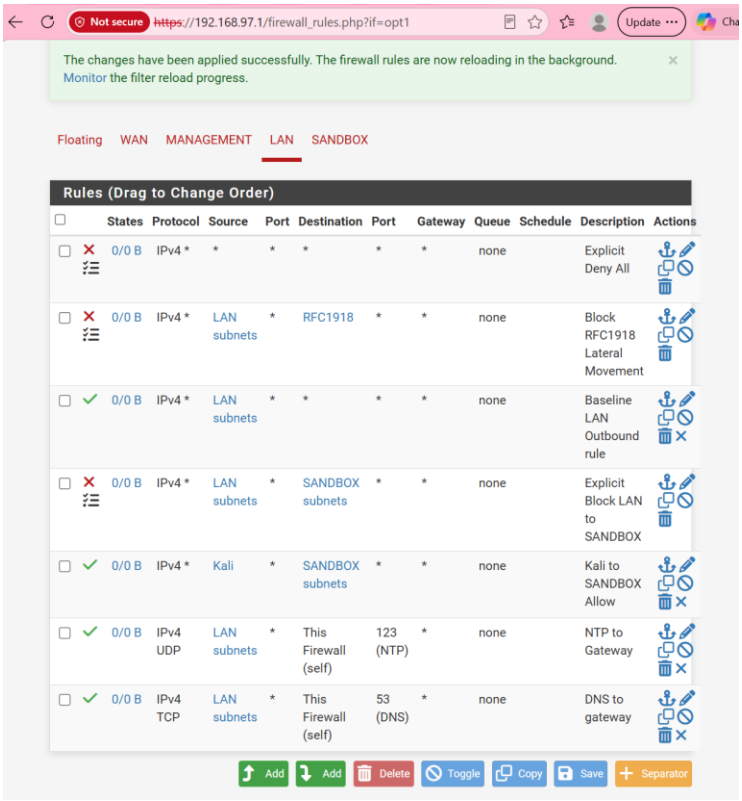


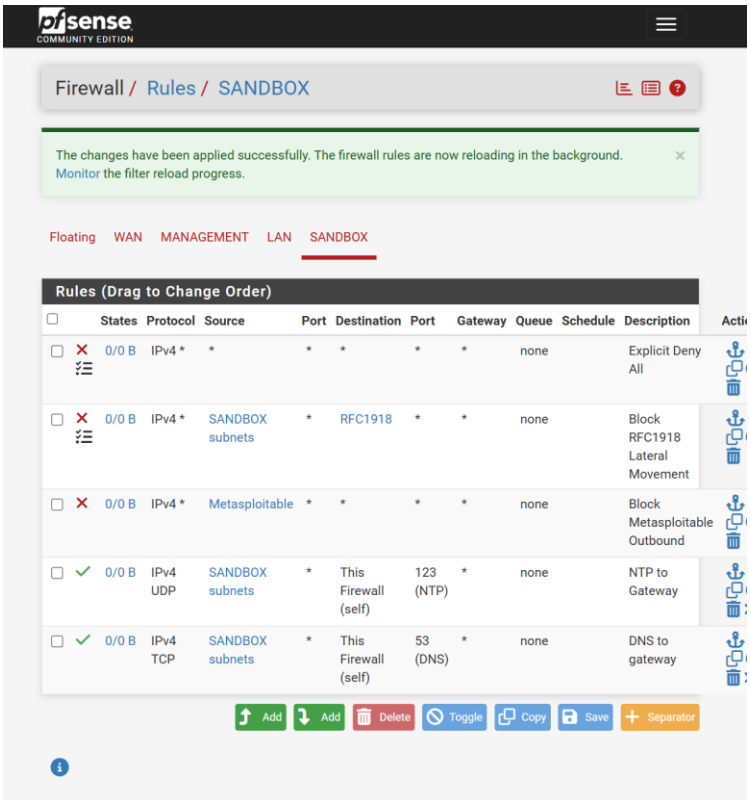
Step 4: Alias Definitions


Not secure https://192.168.97.1/firewall_aliases.php?tab=ip
Update
Chat
pfsense COMMUNITY EDITION
Firewall / Aliases / IP
The alias list has been changed.
The changes must be applied for them to take effect.
Apply Changes
IP Ports URLs All
Firewall Aliases IP
Name Type Values Description Actions
Kali Host(s) 192.168.100.15
Metasploitable Host(s) 192.168.105.35
RFC1918 Network(s) 10.0.0.0/8, 172.16.0.0/32, 192.168.0.0/32 All private networks
Add Import

Interfaces:


The firewall rule configuration has been changed.
The changes must be applied for them to take effect.
Apply Changes
Floating WAN MANAGEMENT LAN SANDBOX
Rules (Drag to Change Order)
States Protocol Source Port Destination Port Gateway Queue Schedule Description
7/1.01 MiB * * * MANAGEMENT Address 443 80 * * Anti-Lockout Rule
0/0 B IPv4 * * * * * * * none Explicit Deny All
0/0 B IPv4 * * * RFC1918 * * none Block RFC1918 Lateral Movement
0/0 B IPv4 TCP * * This Firewall (self) 123 (NTP) * none NTP to Gateway
0/0 B IPv4 TCP 192.168.97.2 * Kali 22 (SSH) * none SH to Kali (Administrative Channel)
0/0 B IPv4 TCP 192.168.97.2 * 192.168.97.1 443 (HTTPS) * none Restrict pfSense Administrative Access
Add Add Delete Toggle Copy Save Separator


Not secure https://192.168.97.1/firewall_rules.php?if=opt1
Update
The changes have been applied successfully. The firewall rules are now reloading in the background.
Monitor the filter reload progress.
Floating WAN MANAGEMENT LAN SANDBOX
Rules (Drag to Change Order)
States Protocol Source Port Destination Port Gateway Queue Schedule Description Actions
0/0 B IPv4 * * * * * * none Explicit Deny All
0/0 B IPv4 * LAN subnets * RFC1918 * * none Block RFC1918 Lateral Movement
0/0 B IPv4 * LAN subnets * * * * none Baseline LAN Outbound rule
0/0 B IPv4 * LAN subnets * SANDBOX subnets * * none Explicit Block LAN to SANDBOX
0/0 B IPv4 * Kali * SANDBOX subnets * * none Kali to SANDBOX Allow
0/0 B IPv4 UDP LAN subnets * This Firewall (self) 123 (NTP) * none NTP to Gateway
0/0 B IPv4 TCP LAN subnets * This Firewall (self) 53 (DNS) * none DNS to gateway
Add Add Delete Toggle Copy Save Separator


pfsense COMMUNITY EDITION
Firewall / Rules / SANDBOX
The changes have been applied successfully. The firewall rules are now reloading in the background.
Monitor the filter reload progress.
Floating WAN MANAGEMENT LAN SANDBOX
Rules (Drag to Change Order)
States Protocol Source Port Destination Port Gateway Queue Schedule Description
0/0 B IPv4 * * * * * * none Explicit Deny All
0/0 B IPv4 * SANDBOX subnets * RFC1918 * * none Block RFC1918 Lateral Movement
0/0 B IPv4 * Metasploitable * * * * none Block Metasploitable Outbound
0/0 B IPv4 UDP SANDBOX subnets * This Firewall (self) 123 (NTP) * none NTP to Gateway
0/0 B IPv4 TCP SANDBOX subnets * This Firewall (self) 53 (DNS) * none DNS to gateway
Add Add Delete Toggle Copy Save Separator

Step 4:

Question 1:

The “Explicit Block LAN to SANDBOX” rule (LAN rule 4). It sits above the “Baseline LAN Outbound (Temporary)” rule, which is a permissive *pass LAN → any*. If the block rule were moved below the baseline rule, LAN-to-Sandbox traffic would hit the permissive “pass any” rule first and be allowed — silently defeating the segmentation between LAN and the vulnerable Sandbox.

Question 2:

The “Block RFC1918 Lateral Movement” rule on the SANDBOX interface. It prevents a compromised Sandbox host (Metasploitable — a deliberately vulnerable machine) from pivoting into the LAN or Management networks. This is the most critical boundary because Sandbox is the zone most likely to be compromised by design; if an attacker who owns Metasploitable could reach trusted internal hosts or the firewall’s management plane, the entire segmentation strategy would collapse. Blocking east-west movement *out* of Sandbox contains the blast radius to the isolated zone, which is the central security goal of the whole architecture. *(The “Block Metasploitable Outbound” rule is a close second — it contains the offensive tooling itself.)*

Question 3:

It’s labeled temporary because it’s an intentionally broad “pass LAN” rule used only to guarantee connectivity while the environment is being built and tested. The risk is that it violates least privilege: it permits LAN hosts to reach *anything* not already explicitly blocked above it, which broadens the exposure surface and can mask the more specific controls you intend to enforce. It should be tightened or removed once the environment is validated, and specific allow rules are in place — i.e., after the setup/testing phase, before the architecture is treated as a hardened or production-like baseline. Leaving it in place long-term would leave an overly permissive path that undermines the segmentation the other rules establish.

Question 4: In a flat network, every host share one segment, so there’s no chokepoint — any single compromise gives an attacker unrestricted lateral access to all other hosts, and there’s little ability to filter or log internal movement. The segmented design forces all

cross-zone traffic through pfSense, where a default-deny posture plus explicit rules controls exactly what each zone may reach: Management can only administer specific hosts, LAN hosts are blocked from Sandbox (except controlled Kali access), and Sandbox can't pivot anywhere. This contains breaches to their zone, enforces least privilege at the network layer, and creates logging points at each boundary. The result is a dramatically smaller exposure surface — a compromise in one zone no longer means compromise of the whole network.

Question 5:

The logged "Block RFC1918 Lateral Movement" rule on the SANDBOX interface (or the Sandbox "Explicit Deny All"). Because no legitimate traffic should ever trigger it, any hit is inherently suspicious — it would reveal a Sandbox host attempting to reach the LAN or Management networks, which is a strong indicator of an active compromise attempting lateral movement / pivoting. That's the most meaningful signal precisely because it's high-signal and low-noise: an allow rule logs lots of normal traffic you'd have to sift through, but a denied-and-logged pivot attempt from the quarantined zone is almost certainly malicious. Even with no endpoint visibility, that single log line tells an investigator that the Sandbox was likely compromised, and the attacker is trying to break up containment.